USENIX

THE ADVANCED COMPUTING
SYSTEMS ASSOCIATION

Stealth BGP Hijacks with uRPF Filtering

Haya Schulmann, *Goethe-Universität Frankfurt and National Research Center for Applied Cybersecurity ATHENE;* Shujie Zhao, *Technische Universität Darmstadt and Fraunhofer SIT*

https://www.usenix.org/conference/woot25/presentation/schulmann

This paper is included in the Proceedings of the
19th USENIX WOOT Conference on Offensive Technologies.

August 11–12, 2025 • Seattle, WA, USA

ISBN 978-1-939133-50-2

Open access to the Proceedings of the
19th USENIX WOOT Conference on Offensive Technologies
is sponsored by USENIX.

ARTIFACT EVALUATED
usenix ASSOCIATION
AVAILABLE

Stealth BGP Hijacks with uRPF Filtering

Haya Schulmann[1], Shujie Zhao[2]

[1]Goethe-Universität Frankfurt and ATHENE
[2]Technische Universität Darmstadt and Fraunhofer SIT

Abstract

Unicast Reverse Path Forwarding (uRPF) is the primary and the standard Source Address Validation (SAV) mechanism to combat IP spoofing and mitigate Denial-of-Service (DoS) and other attacks. However, in this study, we reveal a critical and previously unexplored vulnerability in uRPF that adversaries can stealthily exploit through Border Gateway Protocol (BGP) hijacking. We introduce Stealthy BGP Attack against uRPF (SBA-uRPF), a novel attack vector that leverages prefix hijacking to manipulate uRPF filtering decisions, resulting in the unintended blocking of legitimate traffic and the facilitation of persistent DoS attacks. Due to its hidden nature, SBA-uRPF attacks could pose a significant and persistent security risk.

Through extensive simulation-based analysis, we demonstrate that 99.3% of networks are vulnerable to SBA-uRPF under a full deployment of uRPF, with a potential maximum impact affecting over 59,115 networks (76.3%). Unlike conventional BGP hijacks, which often result in noticeable routing anomalies, SBA-uRPF remains undetectable to the affected networks, making it a particularly dangerous threat. The attack exploits BGP routing loop prevention and customer-preferred routing policies to induce widespread traffic blackholing of victim networks. We show that adversaries can also target fundamental Internet systems, such as DNS, or Internet services, like the web.

Our findings reveal a fundamental weakness in the global routing ecosystem, where a security mechanism designed to prevent attacks can be subverted and turned into an attack vector. We discuss countermeasures, including improvements to BGP security mechanisms such as Route Origin Validation (ROV) and BGPsec. We also consider the challenges in mitigating SBA-uRPF in real-world deployments, and the need for more comprehensive approaches, including solutions involving deployment strategies for uRPF.

Our code and datasets are available at `https://github.com/zsjstart/Stealthy-uRPF-Attack/tree/v1.1.0`.

1 Introduction

In the early days of the Internet the source address at the Internet Protocol (IP) layer header in the received packets was used to identify the origin. Many network services relied on this source IP address for authentication and access control. For example, remote login services, such as rsh, rlogin, rexec, trusted predefined IP addresses and allowed access without requiring additional authentication if the request came from a recognized address. Similarly network devices implemented Access Control Lists (ACLs) on routers and firewalls based on source IP addresses to restrict access to resources. Even the security mechanisms relied on source IP addresses to filter or rate-limit malicious traffic, e.g., in Denial of Service (DoS) attacks.

Attackers quickly realized they could exploit this reliance on source IP addresses by spoofing (forging) the source addresses in packets they send. Since IP does not provide inherent authentication, attackers could manipulate packets to appear as if they originated from some other origin, e.g., a trusted source. This allowed them to bypass authentication mechanisms and launch various attacks, e.g., to gain access to network services, to launch DoS amplification or reflection or DNS cache poisoning attacks [15–17, 22, 32, 43]. IP address spoofing is a fundamental security concern.

To block IP spoofing best practices the networks should apply Source Address Validation (SAV) by enabling ingress and egress filtering RFC2827/BCP38 at the network boundaries to block packets with spoofed source IP addresses [4, 36, 39].

uRPF to block IP spoofing. Unicast Reverse Path Forwarding (uRPF) is a standard method for implementing SAV. uRPF leverages BGP routing tables to validate source addresses, ensuring that only incoming traffic arriving on the correct interface — one that can be used to send traffic back to the source — is accepted. In recent years, uRPF has gained increasing attention from both research community and industry professionals and is currently the primary method to implement SAV against IP spoofing [27, 35, 35, 38, 39]. Leading network infrastructure manufacturers, including Cisco, Huawei, Fortinet, Juniper Networks, and Arista Networks,

support uRPF configuration on their routers and security devices to enhance network security and mitigate IP address spoofing. A recent study identified already 53 networks that have deployed uRPF [35]. uRPF offers significant advantages over alternative SAV techniques like ACLs, which motivates its broader deployment. Industry initiatives, such as MANRS (Mutually Agreed Norms for Routing Security), also promote the implementation of uRPF as a key principle of anti-spoofing filtering, securing the global routing system [1]. With growing support from both academia and industry, uRPF is anticipated to see wider adoption.

Unexpected consequences of uRPF. In this work we show for the first time that uRPF can be exploited to launch effective prefix hijack attacks, we call uRPF assisted hijack. In the course of the attack, an adversary announces a fraudulent route for the victim's prefix, which propagates to the targeted network that enforces uRPF, replacing the legitimate route received via the same interface. Since the malicious route includes the AS number of the uRPF-enabled network as the origin in the AS path, it is discarded to prevent a routing loop. However, this causes the uRPF-enabled network to mistakenly drop legitimate traffic from the victim network, leading to a Denial-of-Service (DoS). Detailed description of this attack is provided in Section 5. We show that this attack is highly effective: just a single stealthy BGP hijack is executed against a specific uRPF-enabled network, impacting not only that network but also its customers. The prefix hijack remains unnoticed by these affected networks.

To evaluate the impact of this attack on the Internet, we develop a methodology for identifying vulnerable networks and for assessing the impact level of a specific attack. As previously mentioned, the impact of an attack targeting an individual vulnerable network is case-specific. To evaluate the extent of the vulnerabilities and understand the impact of uRPF on prefix hijack at full uRPF deployment, we model a hypothetical scenario in which uRPF is universally deployed across the Internet. Under this assumption, we theoretically assess the vulnerability of each uRPF-enabled network to the proposed attack and quantify the potential impact of specific attacks.

Our analysis reveals that a substantial majority (99.3%) of networks could be vulnerable, with a potential maximum impact on 59,115 (76.3%) networks. However, these findings are derived from a theoretical model rather than real-world uRPF deployments, meaning they represent potential security risks rather than actual threats.

To avoid harming the reachability of networks in the Internet we evaluate the impact and extent of our attacks on a simulated environment. Our study provides insights into the potential security implications of uRPF adoption. These findings help point at the need to develop proactive strategies to mitigate the vulnerabilities associated with the deployment of uRPF, paving the way for more resilient and secure inter-domain routing.

Contributions. We make the following contributions:

- We propose a novel stealthy BGP attack, we call SBA-uRPF, that exploits prefix hijacks to manipulate uRPF, causing it to discard legitimate traffic and resulting in a DoS.
- We present methodologies for identifying networks vulnerable to the proposed stealthy BGP attack, along with methods for quantifying the impact.
- We perform an analysis of the extent of the networks vulnerable to SBA-uRPF attacks and the impact of the attacks.
- We discuss potential limitations and countermeasures for preventing SBA-uRPF.
- We make our code and datasets public for reproduction and future research: `https://anonymous.4open.science/r/Stealthy-uRPF-Attack-B57F/`

Ethical considerations. We ensure that our research is ethical and does not inadvertently cause harm or create risks to the broader Internet infrastructure. Our primary focus is on exploring and understanding the negative side-effects of the deployed security mechanism against IP spoofing: uRPF. We follow best practices for ethical research in network security and software security [8, 11, 40]. All tests and evaluations are performed in controlled environments or on simulated platforms, isolated from live production systems. Our precautions prevent any potential disruption to operational networks and services.

Organization. We provide an overview of BGP and prefix hijacks in Section 2. We explain uRPF in Section 3 and the related work in Section 4. We develop the stealth hijack attacks in Section 5. The methodologies for identifying networks vulnerable to our attacks and methodologies for quantifying the impact of our attacks are presented in Section 6. We perform simulations on heuristically derived datasets to analyze the impact of the attacks and the scope of the vulnerable networks in Section 7. We discuss the impact on critical applications in Section 8 and show an extension of the attack in Section 9. We review limitations in Section 10. Countermeasures in Section 11 and conclusion in Section 12.

2 Overview of BGP

Border Gateway Protocol (BGP) [33] is the inter-domain routing system of the Internet. The routers use BGP packets to exchange information about the reachability of prefixes within their Autonomous Systems (ASes). A BGP route/announcement includes an IP prefix and the AS path to that prefix, with the origin AS always located at the end of the path. BGP routers at the border of ASes receive announcements from their neighbors (providers, customers, or peers). When forwarding a BGP update to the next hop, the router prepends its AS number to the AS path.

Prefix hijacks with AS path manipulation. Using BGP any router can claim to origin any prefix, even those it does not legitimately own. This can be done by manipulating the AS path of a prefix, appending or prepending an AS number to the path. For example, AS1 may originate a route for the prefix `1.2.3.0/24`, which is owned by AS2, with an AS path [AS1, ASx], where ASx is an arbitrary AS number. Such bogus BGP announcements can be exploited by adversaries to redirect traffic through their networks. BGP prefix hijacks can be exploited for launching more complex attacks, such as eavesdropping, blackholing, or spam distribution [5, 41, 42].

Routing loop prevention. BGP incorporates built-in mechanisms for routing loop prevention. For example, ASes will discard a BGP announcement if they detect their own AS numbers in the AS path, thereby avoiding routing loops. Our attack exploits prefix hijacks with AS path manipulation to trigger the routing loop prevention mechanism and interfere with the uRPF decision-making process, leading uRPF to incorrectly allow IP-spoofed packets.

Route preference. Upon receiving a BGP update, the router compares it with the existing route for the same prefix and selects the best one for forwarding. Local preference is a configurable BGP attribute used to control route selection, with ASes preferring routes with higher local preference values. Due to economic incentives[1], an AS typically prefers routes learned from its customers over those learned from peers, and routes from peers are preferred over those from providers. In most cases, customer routes have higher local preference values. Additionally, an AS tends to prefer routes with shorter AS paths. Other strategies, such as the Interior Gateway Protocol (IGP) metric, can also be used in route selection [7].

Valley-free routing policy. When an AS forwards a BGP route learned from its provider or peer to another provider or peer, it creates a "valley" on the AS path [37]. Consequently, BGP route propagation between ASes should adhere to the valley-free routing policy, meaning that no valley should appear on the AS path.

3 Blocking Spoofing with uRPF

Source Address Validation (SAV) is the de facto method for preventing IP spoofing-based attacks, as specified in [RFC2827, RFC3704, RFC8704] [4, 36, 39]. Unicast Reverse Path Forwarding (uRPF) is a primary technique for implementing SAV at the boundaries of networks. Upon receiving an incoming packet, uRPF verifies that the source address is valid based on the BGP forwarding routing table. uRPF operates in three modes: strict uRPF, feasible-path uRPF, and loose uRPF [39]. We explain uRPF using example network scenarios.

Figure 1 illustrates an example in which AS7, with uRPF enabled, drops ingress packets from AS5 that have a spoofed source address belonging to AS1. AS1 originates BGP routes

[1] An AS generates revenue by providing transit services to its customers.

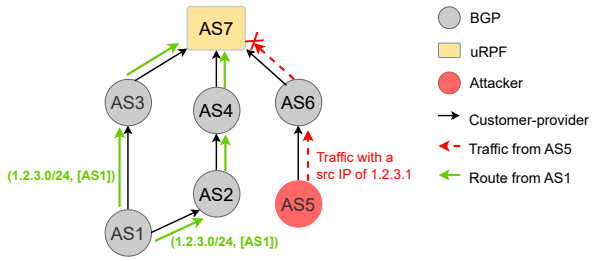

Figure 1: uRPF filtering packets with a forged source (src) IP address.

for its prefix `1.2.3.0/24`. One route arrives at AS7 via AS3 (a provider of AS1), while another reaches AS7 through AS2 and AS4 (AS2's provider). Assuming AS7 prefers a shorter AS path during route selection, the route through AS3 is chosen as the best route for forwarding packets to AS1. In strict mode, uRPF accepts a packet only if it arrives on the same interface used to forward the reply packet back to the source. This means that with strict uRPF traffic with a source IP from AS1 is only expected to reach AS7 via AS3. However, this mode of uRPF may lead to the loss of legitimate traffic in cases of asymmetric routing or multihoming [4]. For example, when AS1 sends a packet to AS7, it may traverse AS2 and AS4 if the route through AS3 is unavailable. In this case, AS7 drops the packet because it arrives on an unexpected interface.

To address this issue, feasible-path uRPF was developed. Unlike strict uRPF, which requires incoming packets to arrive via the best route, feasible-path uRPF allows for the consideration of an alternative route through which the packet can also reach its destination. In Figure 1, if AS7 adopts uRPF in feasible-path mode, it permits traffic with a source address from AS1 to arrive via either AS3 or AS4. This approach provides greater flexibility in terms of directionality, making feasible-path uRPF more effective in complex network architectures [35].

However, when customers announce different prefixes to different transit providers, legitimate packets may still be mistakenly dropped by feasible-path uRPF. To address this RFC8704 [39] introduced enhanced feasible-path uRPF, which further extends direction flexibility by considering all routes from the same AS origin. For example, in Figure 1, if AS1 originates a route for `1.2.3.0/24` that passes through AS3 to reach AS7, and another route for `1.2.4.0/24` that traverses AS2 and AS4 to reach AS7, enhanced feasible-path uRPF allows AS7 to accept traffic from both subnets, `1.2.3.0/24` and `1.2.4.0/24`, arriving either through AS3 or AS4. In other words, both interfaces connected to AS3 and AS4 are expected to receive traffic from AS1.

In contrast, loose uRPF operates in a simpler manner, filtering only packets with bogon or unallocated IP addresses. RFC8704 [39] and the MANRS guide [27] recommend that network operators of smaller or simpler networks such as single-homed (stub) ASes employ strict uRPF, while for larger

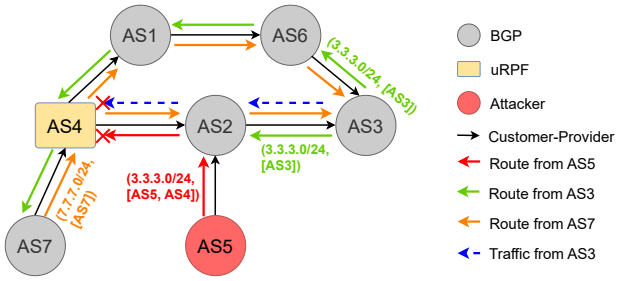

Figure 2: An example of a stealthy prefix hijack against uRPF-protected networks, where the uRPF-enabled network is directly connected to the bridging network.

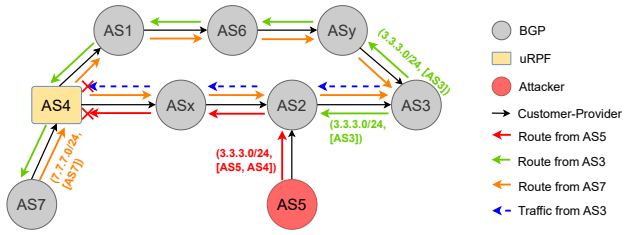

Figure 3: An example of a stealthy prefix hijack against uRPF-protected networks, where the uRPF-enabled network is not directly connected to the bridging network.

or more complex networks, feasible-path uRPF is considered to be the optimal choice.

Many efforts have been made to measure the deployment of Source Address Validation (SAV) across the Internet in order to evaluate the potential attack surface [6,10,21,23–26,28,35].

As awareness to attacks with spoofed IP packets is increasing, the adoption of uRPF also growth. In this work we identify a novel attack vector which exploits support of uRPF, and explore the impact of this attack. Our attack that exploits the inherent nature of uRPF that validates the source address based on the direction from which the traffic arrives (see more details in Section 5).

4 Related Work

A range of stealthy BGP attacks have been proposed in the existing literature.

Adversaries manipulate the AS path of a hijacked route by intentionally appending the correct origin AS at the end of the path, making the route appear legitimate. This type of prefix hijack is stealthy to current BGP prevention and mitigation systems [18]. The Resource Public Key Infrastructure (RPKI) [20], which links prefixes to Autonomous System (AS) numbers (ASNs) and their corresponding cryptographic public keys through Route Origin Authorizations (ROAs), has been standardized as a means of preventing BGP hijacks. Route Origin Validation (ROV) [19] verifies the validity of the origin AS in BGP announcements by comparing it with the ROAs. However, ROV is blind to the prefix hijack described above as the hijacked route has a valid origin AS, allowing it to bypass the detection.

Morillo et al. [31] introduced a hidden BGP hijack resulting from ROV filtering along the AS path, which impacts the data plane (actual traffic flows). To mitigate this hidden hijack, the authors proposed an approach called ROV++. However, when the AS enforcing ROV receives both valid and malicious routes from the same BGP neighbor, ROV++ blackholes the invalid announcement, potentially leading to DDoS attacks.

Birge-Lee et al. [7] proposed SICO, a stealthy BGP interception attack that exploits BGP communities—such as LowerPref, NoExportSelect, and NoExportAll—to manipulate local route preferences and export behaviors, thereby controlling the propagation of bogus announcements. However, the lack of standardized specifications for BGP communities may limit the feasibility of SICO.

In addition, BGP hijacks are often crafted to remain invisible to public route collectors, evading detection by global BGP monitoring systems [29]. The key idea behind these hijacks is to manipulate the route selection process of ASes peering with route collectors, preventing them from feeding malicious routes to the collectors. Milolidakis et al. [30] employed various strategies for crafting stealthy hijacks targeting route collectors, including using the same prefix as the victim but with a longer AS path, exploiting the route loop prevention mechanism, and selectively exporting hijacks to specific neighbors.

In contrast, our attack leverages BGP hijacking to control the filtering behavior of uRPF, which is undetectable to the affected networks.

5 Attack Models

This section introduces a novel stealthy attack that exploits BGP hijacking to manipulate the uRPF filtering behavior.

The basic idea behind this attack is straightforward. Adversaries initiate a malicious BGP route that outcompetes the legitimate route in the route selection process. The bogus route reaches the targeted network employing uRPF via the same interface as the legitimate route. However, it is ultimately discarded after being identified as invalid. As a result, the target network fails to observe the victim prefix on the expected path, causing uRPF to mistakenly reject legitimate traffic.

To launch this attack, adversaries exploit the routing policy where ASes prefer routes learned from customers over those learned from peers or providers. This ensures that a malicious route from a customer is selected as the best export route. Additionally, the attacker manipulates the AS path by appending the uRPF network's AS number to the end, triggering the BGP routing loop prevention mechanism in the targeted network, which causes the forged route to be discarded.

Figure 2 shows that an attacker within network AS5 originates a BGP route for the prefix `3.3.3.0/24`, which belongs to AS3, and appends AS4 to the end of the AS path, making it appear as if the fake route originates from AS4 (see the red

arrow). Assume that AS5 is a customer of AS2, while AS3 is either a provider or peer of AS2 (as illustrated in the figure, AS3 is a provider of AS2). In our work, we refer to AS2 as a bridging network. As mentioned earlier, due to economic incentives, routes learned from a customer are preferred over those learned from a provider or peer. Consequently, when AS2 receives two routes for the prefix `3.3.3.0/24`—one from AS5 and another from AS3—it selects the route from AS5 and propagates it to AS4.

However, AS4 detects its own AS number in the AS path and rejects the malicious route to prevent a routing loop. AS4, which deploys uRPF to prevent source IP spoofing, then only observes the legitimate route for the prefix `3.3.3.0/24` arriving via AS1 (see the green arrow). This means that packets with source IP addresses within the prefix `3.3.3.0/24` are only accepted on the interface connected to AS1.

Meanwhile, AS7, as a customer of AS4, announces a route for its prefix `7.7.7.0/24` (see the orange arrow). This announcement is first learned by AS4 and then AS4 propagates it via two AS paths: [AS2] and [AS1, AS6] to AS3. Recall that AS3 is either a provider or peer of AS2 (in the figure, AS3 is a provider). Under the valley-free BGP routing policy, AS4 must be a customer of AS2 so that the route learned from AS4 can be propagated by AS2 to AS3.

In this scenario, clients within AS7 send requests to a server within AS3. AS3 responds with packets using source IP addresses from the prefix `3.3.3.0/24`, destined for the network `7.7.7.0/24`. Based on the shortest AS path criterion in the best route selection process, AS3 selects the route that passes through AS2 and then to AS4. Consequently, this traffic is expected to flow through AS2 to AS4 before reaching its destination AS7 (see the blue arrow). However, due to the enforcement of the uRPF, AS4 blocks traffic sourced from the prefix `3.3.3.0/24` when it arrives via AS2, resulting in the traffic being dropped. This leads to a denial-of-service (DoS).

Similar to AS7, all other customer networks of AS4—whether directly connected or connected indirectly through one or more intermediary customer networks, collectively known as AS4's customer cone—could also be vulnerable to this DoS attack. Notably, AS4's provider or peer networks will not be affected, as BGP announcements originating from these networks cannot propagate to AS2 and then to AS3, in accordance with the valley-free BGP routing policy.

We use prefix hijacks instead of subprefix hijacks, as the latter cannot be leveraged to execute this stealthy attack. Even after dropping the malicious subprefix route, AS4 can still observe the legitimate route for the victim prefix reaching it via AS2.

uRPF-protected networks: We define uRPF-enabled networks and all downstream networks within their customer cones as uRPF-protected networks (such as AS4 and AS7). All of these uRPF-protected networks could be compromised by this stealthy attack.

Definition: Adversaries originate a forged BGP announcement, falsely claiming the uRPF-enabled network as the origin, thereby triggering routing loop prevention. As a result, legitimate traffic originating from a victim network (e.g., AS3) and destined for uRPF-protected networks is dropped, causing a denial-of-service (DoS). The prefix hijack in this attack is concealed from uRPF-protected networks. We thus refer to this attack as a **s**tealthy **B**GP **a**ttack abusing **uRPF**, denoted as **SBA-uRPF**.

Extension model: Figure 3 illustrates another example of stealthy prefix hijacks targeting uRPF-protected networks. Unlike the scenario shown in Figure 2, this example introduces an extended attack model where the targeted uRPF network (AS4) is connected to the bridging network (AS2) through one or more intermediary networks (such as ASx). This extended model potentially creates additional opportunities for attackers to carry out this stealthy BGP hijack, as it removes the requirement for the targeted uRPF network to be directly connected to the bridging network.

Requirements: As outlined above, certain requirements must be met to execute this attack. These are summarized below:

- The targeted network (e.g., AS4) applies uRPF to incoming packets.
- The attacker's network (e.g., AS5) is a customer of the bridging network (e.g., AS2) while the victim network (e.g., AS3) is the bridging network's provider or peer.
- The targeted uRPF network must be within the customer cone of the bridging network, either as a direct customer, as shown in Figure 2, or as an indirect customer, as illustrated in Figure 3.
- The best route between the targeted uRPF network and the victim network must pass through the bridging network, as seen in the paths [AS4, AS2, AS3] in Figure 2 and [AS4, ASx, AS2, AS3] in Figure 3.

Impact: SBA-uRPF exploits the routing policy used for loop prevention within an AS. It is specifically tailored to each uRPF-enabled network. As a result, the impact of this attack is limited to the targeted network employing uRPF and its associated customer cone.

Applicability: Recall that strict uRPF, feasible-path uRPF, and enhanced feasible-path uRPF operate based on the arrival direction of incoming traffic. As a result, SBA-uRPF attacks can target all three uRPF modes. However, loose uRPF filters packets with bogon or unallocated IP addresses, regardless of directionality. Given this, loose uRPF can not be abused by the proposed attack. Our study thus excludes the analysis of this mode.

6 Methodology

In this section, we present the methodologies to identify uRPF-enabled networks that are vulnerable to SBA-uRPF attacks and methods to quantify the impact.

Following the requirements outlined in Section 5, we examine networks that deploy uRPF to determine whether they could be targeted by a stealthy prefix hijack (e.g., AS4 in Figure 2 and Figure 3). For a given uRPF-enabled network, we iterate over its providers to identify whether any provider could act as a bridging network (e.g., AS2). As previously mentioned, a bridging network must have a customer network that attackers can exploit, as well as provider/peer networks that could become victims. Additionally, the victim AS should observe that the best route to the uRPF network under examination passes through the bridging network. To verify this, we simulate route announcements from the uRPF network for its prefix (e.g., 4.4.4.0/24) and examine the routing table of the potential victim network. Once an appropriate bridging network is identified, the uRPF network under examination is recognized as vulnerable to SBA-uRPF attacks.

If no suitable bridging network is found, we continue searching within the providers of the uRPF network's providers. In this scenario, we can identify an indirectly connected bridging network, as illustrated in Figure 3. Listing 1 provides Python functions that identify whether a given uRPF-enabled network is vulnerable to SBA-uRPF attacks.

As mentioned in Section 5, the impact of a specifically crafted prefix hijack is confined to the targeted uRPF-enabled network and the networks within its customer cone, so-called uRPF-protected networks. To quantify the impact, we examine the number of affected uRPF-protected networks. The greater the number of affected networks, the larger the impact.

7 Assessing Extent of Vulnerable Networks

In this section, we assess the vulnerability of Internet networks to SBA-uRPF attacks and evaluate the impact of attacks targeting individual vulnerable networks.

To simulate the propagation of BGP announcements, we use a recently developed and publicly available BGP simulator[2] [13], which is built upon the AS relationships provided by CAIDA [9], consisting of 77,505 ASes that include 65,295 stub or multihomed, 12,191 transit, and 19 tier-1 networks. The simulator sets up BGP routing policies following the principles defined by [14] (Gao-Rexford).

As discussed in Section 6, the impact of an individual prefix hijack is limited to the targeted network using uRPF and the networks within its customer cone. We do not analyze the impact at varying deployment rates of uRPF. This is because, as uRPF adoption increases across the Internet, the potential attack surface expands, exposing more uRPF-enabled networks to SBA-uRPF attacks. Instead, we examine each network node in the simulator described in Section 6 to examine its vulnerability to being targeted by a stealthy prefix hijack, assuming they all employ uRPF.

For each network node, we identify bridging networks (e.g., AS2 in Figures 2 and 3). As outlined in Section 6, we also simulate BGP announcements and confirm that the route to the

[2] https://github.com/jfuruness/bgpy_pkg

Listing 1 Python functions to identify vulnerable uRPF networks.

```python
"""
 network_graph (dict): Representation of the AS topology where keys are AS numbers, and values are their providers, customers, and peers.
 urpf_network_asn (int): AS number of the uRPF-enabled network to evaluate.
 prefix_of_urpf_network: The prefix owned by the uRPF-enabled network.
 checked_asn (int): AS number of the network to be checked
"""
def is_vulnerable_urpf_network(network_graph, urpf_network_asn, prefix_of_urpf_network):
    return has_bridging_network(network_graph, urpf_network_asn, prefix_of_urpf_network)

#True if the uRPF network is vulnerable, False otherwise.
def has_bridging_network(network_graph, checked_asn, prefix_of_urpf_network):
    # Iterate over providers of the AS under examination
    for provider in network_graph[checked_asn]['providers']:
        # Check if the provider could be a bridging network
        customers = network_graph[provider]['customers']
        peers = network_graph[provider]['peers']
        providers = network_graph[provider]['providers']

        # A bridging network must have at least two customers (one of which is the targeted uRPF network) and at least one provider/peer network
        if len(customers) > 1 and (providers or peers):
            # Check if victim AS observes the best route through the bridging network
            for AS in providers:
                routing_table = AS.get_routing_table()
                as_path = routing_table[prefix_of_urpf_network]
                if provider in as_path:
                    return True
            for AS in peers:
                routing_table = AS.get_routing_table()
                as_path = routing_table[prefix_of_urpf_network]
                if provider in as_path:
                    return True

        if has_bridging_network(network_graph, provider, prefix_of_urpf_network):
            return True

    return False
```

	Tier-1	Transit	Edge
Direct connection	0	11,959	63,157
Indirect connection	0	86	1,751
Bridging (mean)	0	3	2
Victim (mean)	0	1,280	615
Attacker (mean)	0	3,025	1,448
Attacks	0	1,781,854	818,355
Impact (mean)	0	1,141	1
Impact (maximum)	0	59,115	1

Table 1: Simulation statistics across three different types of vulnerable networks: tier-1, transit, and edge networks.

examined network in the potential victim network's routing table traverses the bridging network. Once a bridging network is identified, the network node is considered vulnerable to the SBA-uRPF attack. For simplicity, our study focuses on identifying bridging networks that match the structures shown in Figures 2 and 3. Consequently, the number of identified bridging networks is lower than the actual number, as networks like AS3, which could also serve as bridging networks, are excluded from our analysis.

Table 1 demonstrates statistical results from simulations. We identified 75,116 vulnerable networks with a directly connected bridging network (as indicated by "Direct connection" in the table), including 11,959 transit networks and 63,157 edge networks. 1,837 vulnerable networks with an indirectly connected bridging network (as indicated by "Indirect connection") were detected, of which 86 are transit networks and 1,751 are edge networks. *This suggests that, under the assumption of uRPF adoption, a vast majority (99.3%) of networks across the Internet could be vulnerable to SBA-uRPF attacks.* Also, it can be seen that Tier-1 networks are not vulnerable. This is because, they lack providers, meaning no bridging networks can be identified for them. In contrast, 64,908 (99.4%) edge networks and 12,045 (98.8%) transit networks could potentially be targeted by SBA-uRPF attacks.

Subsequently, for each type of vulnerable network, we examined the mean number of bridging networks, victim networks, and attacker networks that can be exploited for launching SBA-uRPF attacks, as indicated by "Bridging (mean)", "Victim (mean)", and "Attacker (mean)" in the table. As observed, vulnerable transit networks exhibit larger numbers compared to vulnerable edge networks. This is reasonable, as larger networks tend to have more neighboring networks, thereby providing more options for adversaries. Our analysis shows that for vulnerable transit networks, a total of 1.7 million potential attacks could be executed by pairing different attacker and victim networks.

We then examined the impact level of SBA-uRPF attacks. Recall that a specific SBA-uRPF attack can affect both the vulnerable network itself and all networks within its customer cone. Vulnerable edge networks have the lowest impact level. As shown in the table, only the vulnerable network itself can be affected since these networks do not have any customers. In contrast, an average of 1,141 networks would be impacted for vulnerable transit networks. Specifically, among these, 1,043 have a customer cone size greater than 100, of which 748 (71.7%) are customers of tier-1 networks, indicating their proximity to the core of the Internet. These networks are expected to serve a larger number of customers, suggesting that SBA-uRPF attacks pose a higher security risk to them. In these cases, tier-1 networks act as bridging networks, resulting in a maximum potential impact on 59,115 networks. However, due to the robust security measures within tier-1 networks, executing such attacks in practice may be challenging. The associated difficulties and mitigations will be explored in our future work.

8 Impact on Critical Applications

IP spoofing is a fundamental technique used to launch various attacks, including DDoS attacks, DNS/NTP amplification attacks, and TCP connection detection/hijacking [12, 15]. These attacks pose a significant security threat to critical Internet infrastructures such as DNS, NTP, and web servers.

As a standardized method for preventing IP spoofing, uRPF is expected to be adopted by network operators, particularly to protect the critical applications mentioned above. However, the abuse of uRPF through SBA-uRPF attacks introduces another significant threat to these critical servers operating behind uRPF protection.

Consider a scenario where a DNS server is running within AS7, as shown in Figures 2 and 3. If AS4 becomes the target of an SBA-uRPF attack, queries from DNS clients within the victim network, AS3, would be unable to reach the DNS server, resulting in a denial-of-service (DoS) attack. Similarly, if a DNS server is located within AS3, DNS clients behind AS4 would not receive responses from the server, also leading to a DoS.

9 Extension: Attacks with Shorter AS Path

The attack proposed in Section 5 relies on the customer route preference policy, which limits the selection of the attacker's network. However, this limitation does not significantly affect the feasibility of SBA-uRPF attacks, as demonstrated by our simulation results.

Adversaries can, however, exploit another routing policy where ASes prefer shorter AS paths, thereby extending the attack. For instance, the bridging network in Figure 2 and Figure 3 has no other customers besides AS4, and AS5 is also its provider network, similar to AS3. In this case, adversaries within AS5 originate a route for the prefix `z.z.z.0/24` owned by ASz, an indirect customer of AS3, and propagate this route to AS2 via three hops. AS2 observes two routes for `z.z.z.0/24`: one from AS5 with an AS path [AS5, AS4], and another from AS3 with an AS path length of three. Since

both AS5 and AS3 are providers of AS2, these routes have the same local preference [7]. For routes with the same prefix and local preference, ASes prefer the route with a shorter AS path. As a result, AS2 selects the malicious route from AS5 for export.

We leave the assessment of the feasibility and impact of this extended attack for future work.

10 Limitations and Challenges

Our analysis provides an upper bound. We assume that networks prefer BGP routes learned from their customers over those from their providers or peers. However, in practice, networks may implement more complex routing policies. For example, they may use BGP communities to adjust local preferences and control route export behavior [7]. In Figure 2, AS2 can apply BGP communities such as *LowerPref* to reduce the preference for routes learned from its customers. In this case, the attack would not succeed. As a result, the number of networks vulnerable to the proposed attack may be overestimated.

Realistic challenges. Additionally, the study assumes that every network adopts uRPF, leading to a theoretical analysis that does not accurately reflect real-world conditions. Future work will incorporate real-world settings for a more practical evaluation of the attack's impact. Additionally, our simulator relies on AS relationships provided by CAIDA, and any inaccuracies in CAIDA's data could also impact our results. However, the confidentiality of network operators' routing policies and data on AS relationships makes a realistic evaluation challenging.

Attack is simple to launch. Upon identifying vulnerable networks that have adopted uRPF, an adversary can exploit prefix hijacking and AS path manipulation to influence uRPF's decision-making process. From a technical perspective, SBA-uRPF is relatively straightforward to implement, as crafting a prefix hijack with a modified AS path is not particularly challenging. Our simulation results reveal millions of possible attack scenarios that adversaries could exploit. However, gaining control over an AS is non-trivial. Once control is established, the adversary's network becomes fixed, limiting their operational flexibility, as SBA-uRPF is a highly targeted attack. In such cases, the adversary may find few or no exploitable networks, significantly reducing the attack's effectiveness.

Load on adversary. Prefix hijacks initiated by attackers often go unnoticed by the affected networks. Although the uRPF-enabled network can observe the bogus route, it merely filters it out to prevent routing loops rather than identifying it as a hijack. This inherent behavior makes SBA-uRPF attacks particularly undetectable to targeted networks, potentially constituting a long-term security threat. However, these hijacks can propagate globally across the Internet through bridging networks. As a result, traffic from networks that accept the fraudulent announcement is redirected to the attacker's network. Unlike conventional prefix hijacking, which is typically an untargeted attack, adversaries deploying SBA-uRPF specifically target uRPF-enabled networks while ensuring that no redirected traffic reaches their own infrastructure. Nevertheless, the unintended consequences of prefix hijacking impose an additional processing burden on the adversary's network due to the influx of unwanted traffic. Additionally, the propagated prefix hijack can be observed and detected by global BGP route monitoring systems such as RouteViews [34] and RIPE [2], which could undermine the stealth of SBA-uRPF. Future work will address the undesired impacts of prefix hijacking and enhance the stealth capabilities of SBA-uRPF.

11 Countermeasures

Our simulations reveal that a substantial number of networks on the Internet could suffer from SBA-uRPF attacks. This finding may discourage the widespread adoption of uRPF. Therefore, countermeasures should be implemented to mitigate SBA-uRPF attacks in future efforts.

Recall that the attack involves prefix hijacking with AS path manipulation to trigger BGP routing loop prevention. Given this, one possible countermeasure is for ASes (such as AS2 in Figure 2) to deploy mechanisms that defend against AS path manipulation. Existing path validation mechanisms, such as BGPsec [RFC8205] and Autonomous System Provider Authorization (ASPA) [3], have been designed to address this issue. Assuming that AS2 in Figure 2 adopts BGPsec, the BGPsec-enabled routers would reject the bogus route, as the signature corresponding to AS4 in the path would fail validation. Additionally, if the bridging network (AS2) deploys Route Origin Validation (ROV), the route with a fake origin would be classified as RPKI-invalid and discarded by the router. As a result, when AS2 employs BGPsec or ROV, the malicious route is prevented from propagating. Instead, AS2 forwards the legitimate route originating from AS3 to AS4, thereby mitigating the attack.

However, if an uRPF-enabled network deploys ROV, adversaries may be able to abuse ROV to drop bogus BGP announcements instead of exploiting routing loop prevention. The feasibility of such an attack is limited, as it requires the targeted network to deploy ROV and the victim network to have ROAs. Future work will explore additional countermeasures.

12 Conclusions

Unicast Reverse Path Forwarding (uRPF) is the primary security measure for Source Address Validation (SAV) to mitigate IP spoofing attacks. However, like many security mechanisms, uRPF is a double-edged sword: while it enhances security, our research demonstrates that uRPF itself introduces a high-risk attack vector that could be exploited at Internet scale. We show how adversaries can exploit uRPF's decision properties, specifically those related to the arrival direction of traffic, to manipulate its filtering behavior. By leveraging

prefix hijacking, attackers can cause uRPF to unintentionally discard legitimate packets, resulting in a Denial-of-Service (DoS) attack. We call this attack SBA-uRPF. The stealthy nature of SBA-uRPF means that affected networks are often unaware of ongoing attacks, making it a serious threats to Internet routing security.

To better understand the scope of this vulnerability, we first propose methodologies to identify uRPF-adopting networks that are susceptible to SBA-uRPF. Assuming universal uRPF deployment (a hypothetical scenario where every network adopts uRPF), we conduct a simulation-based study to assess the extent of vulnerabilities and the potential impact of an attack. Our findings reveal that an overwhelming majority (99.3%) of networks across the Internet could be vulnerable to SBA-uRPF attacks. In the worst-case scenario, up to 59,115 networks (76.3%) could be affected.

We discuss the limitations of our study, the potential impact of SBA-uRPF on critical systems, such as DNS servers, and propose potential attack extensions and countermeasures. While our analysis is based on simulated environments and theoretical uRPF configurations, our insights reveal significant security risks associated with uRPF adoption.

Acknowledgements

This work has been co-funded by the German Federal Ministry of Education and Research and the Hessen State Ministry for Higher Education, Research and Arts within their joint support of the National Research Center for Applied Cybersecurity ATHENE and by the Deutsche Forschungsgemeinschaft (DFG, German Research Foundation) SFB 1119.

References

[1] Mutually Agreed Norms for Routing Security (MANRS) Implementation Guide. https://www.ripe.net/publications/docs/ripe-706/?utm_source=chatgpt.com, 2018.

[2] RIPE Network Coordination Centre. http://www.ripe.net/, September 2024.

[3] A. Azimov, E. Bogomazov, R. Bush, K. Patel, and J. Snijders. Verification of AS_PATH Using the Resource Certificate Public Key Infrastructure and Autonomous System Provider Authorization, November, 2020. https://datatracker.ietf.org/doc/html/draft-ietf-sidrops-aspa-verification-06.

[4] Fred Baker and Pekka Savola. Rfc3704: Ingress filtering for multihomed networks, 2004.

[5] Hitesh Ballani, Paul Francis, and Xinyang Zhang. A Study of Prefix Hijacking and Interception in the Internet. In *ACM SIGCOMM Computer Communication Review*, volume 37, pages 265–276. ACM, 2007.

[6] Robert Beverly and Steven Bauer. The spoofer project: Inferring the extent of source address filtering on the internet. In *Usenix Sruti*, volume 5, pages 53–59, 2005.

[7] Henry Birge-Lee, Liang Wang, Jennifer Rexford, and Prateek Mittal. Sico: Surgical interception attacks by manipulating bgp communities. In *Proceedings of the 2019 ACM SIGSAC Conference on Computer and Communications Security*, CCS '19, page 431–448, New York, NY, USA, 2019. Association for Computing Machinery.

[8] Matt Bishop and David V. Bailey. Ethical issues in computer security research: What practitioners say. In *Proceedings of the 4th Workshop on Ethics in Computer Security Research (WECSR)*. Springer, 2008.

[9] CAIDA. https://publicdata.caida.org/datasets/as-relationships/serial-1/. [Online; accessed 10-Oct-2023].

[10] Tianxiang Dai and Haya Shulman. Smap: Internet-wide scanning for spoofing. In *Annual Computer Security Applications Conference*, pages 1039–1050, 2021.

[11] David Dittrich and Erin Kenneally. The menlo report: Ethical principles guiding information and communication technology research. Technical Report 11-01, U.S. Department of Homeland Security, August 2012.

[12] Xuewei Feng, Qi Li, Kun Sun, Chuanpu Fu, and Ke Xu. Off-path tcp hijacking attacks via the side channel of downgraded ipid. *IEEE/ACM transactions on networking*, 30(1):409–422, 2021.

[13] Justin Furuness, Cameron Morris, Reynaldo Morillo, Amir Herzberg, and Bing Wang. Bgpy: The bgp python security simulator. In *Proceedings of the 16th Cyber Security Experimentation and Test Workshop*, CSET '23, page 41–56, New York, NY, USA, 2023. Association for Computing Machinery.

[14] Lixin Gao and Jennifer Rexford. Stable internet routing without global coordination. *IEEE/ACM Trans. Netw.*, 9(6):681–692, 2001.

[15] Harm Griffioen, Kris Oosthoek, Paul van der Knaap, and Christian Doerr. Scan, test, execute: Adversarial tactics in amplification ddos attacks. In *Proceedings of the 2021 ACM SIGSAC Conference on Computer and Communications Security*, CCS '21, page 940–954, New York, NY, USA, 2021. Association for Computing Machinery.

[16] Brendon Harris and Ray Hunt. Tcp/ip security threats and attack methods. *Computer communications*, 22(10):885–897, 1999.

[17] Amir Herzberg and Haya Shulman. Fragmentation Considered Poisonous: or one-domain-to-rule-them-all.org. In *CNS 2013. The Conference on Communications and Network Security. IEEE*. IEEE, 2013.

[18] Thomas Holterbach, Thomas Alfroy, Amreesh Phokeer, Alberto Dainotti, and Cristel Pelsser. A system to detect {Forged-Origin}{BGP} hijacks. In *21st USENIX Symposium on Networked Systems Design and Implementation (NSDI 24)*, pages 1751–1770, 2024.

[19] Geoff Huston and George Michaelson. Validation of route origination using the resource certificate public key infrastructure (pki) and route origin authorizations (roas). Technical report, 2012.

[20] S. Kent and K.seo. An Infrastructure to Support Secure Internet Routing. RFC 6480, February 2012.

[21] Marc Kührer, Thomas Hupperich, Christian Rossow, and Thorsten Holz. Exit from hell? reducing the impact of {Amplification}{DDoS} attacks. In *23rd USENIX Security Symposium (USENIX Security 14)*, pages 111–125, 2014.

[22] Sanjeev Kumar. Smurf-based distributed denial of service (ddos) attack amplification in internet. In *Second International Conference on Internet Monitoring and Protection (ICIMP 2007)*, pages 25–25. IEEE, 2007.

[23] Qasim Lone, Alisa Frik, Matthew Luckie, M Korczyński, Michel van Eeten, and Carlos Ganán. Deployment of source address validation by network operators: a randomized control trial. *Proceedings of the IEEE Security and Privacy (S&P)*, 2022.

[24] Qasim Lone, Matthew Luckie, Maciej Korczyński, Hadi Asghari, Mobin Javed, and Michel Van Eeten. Using crowdsourcing marketplaces for network measurements: The case of spoofer. In *2018 Network Traffic Measurement and Analysis Conference (TMA)*, pages 1–8. IEEE, 2018.

[25] Qasim Lone, Matthew Luckie, Maciej Korczyński, and Michel Van Eeten. Using loops observed in traceroute to infer the ability to spoof. In *International Conference on Passive and Active Network Measurement*, pages 229–241. Springer, 2017.

[26] Matthew Luckie, Robert Beverly, Ryan Koga, Ken Keys, Joshua A Kroll, and K Claffy. Network hygiene, incentives, and regulation: deployment of source address validation in the internet. In *Proceedings of the 2019 ACM SIGSAC Conference on Computer and Communications Security*, pages 465–480, 2019.

[27] MANRS. Anti-Spoofing – Preventing traffic with spoofed source IP addresses. https://www.manrs.org/netops/guide/antispoofing/. [Online; accessed 25-Jan-2023].

[28] Jared Mauch. Spoofing ASNs. https://seclists.org/nanog/2013/Aug/132. [Online; accessed 25-Jan-2023].

[29] Alexandros Milolidakis. Bgp hijackers that evade public route collectors.

[30] Alexandros Milolidakis, Tobias Bühler, Kunyu Wang, Marco Chiesa, Laurent Vanbever, and Stefano Vissicchio. On the effectiveness of bgp hijackers that evade public route collectors. *IEEE Access*, 11:31092–31124, 2023.

[31] Reynaldo Morillo, Justin Furuness, Cameron Morris, James Breslin, Amir Herzberg, and Bing Wang. Rov++: Improved deployable defense against bgp hijacking. In *NDSS*, 2021.

[32] Robert T. Morris. A weakness in the 4.2bsd unix tcp/ip software. *ATT Bell Laboratories Technical Report*, 1985. Discusses weaknesses in TCP sequence number generation, later exploited in attacks like Mitnick's.

[33] Yakov Rekhter, Susan Hares, and Tony Li. A Border Gateway Protocol 4 (BGP-4). RFC 4271, January 2006.

[34] RouteViews. http://www.routeviews.org. [Online; accessed 13-Nov-2020].

[35] Haya Schulmann and Shujie Zhao. Insights into sav implementations in the internet. In *International Conference on Passive and Active Network Measurement*, pages 69–87. Springer, 2024.

[36] Daniel Senie and Paul Ferguson. Network Ingress Filtering: Defeating Denial of Service Attacks which employ IP Source Address Spoofing. RFC 2827, May 2000.

[37] Haya Shulman and Shujie Zhao. Poster: Lemon: Global route leak monitoring service. In *Proceedings of the ACM SIGCOMM 2023 Conference*, pages 1111–1113, 2023.

[38] Philip Smith. Unicast Reverse Path Forwarding, September, 2023. https://www.bgp4all.com.au/pfs/_media/workshops/03-urpf.pdf.

[39] K Sriram, D Montgomery, and J Haas. Rfc 8704 enhanced feasible-path unicast reverse path forwarding. 2020.

[40] Latanya Sweeney, Mercè Crosas, and Michael Bar-Sinai. Sharing sensitive data with confidence: The data tags system. *Technology Science*, September 2015.

[41] Pierre-Antoine Vervier and Olivier Thonnard. Spamtracer: How stealthy are spammers? In *2013 Proceedings IEEE INFOCOM*, pages 3477–3482. IEEE, 2013.

[42] Pierre-Antoine Vervier, Olivier Thonnard, and Marc Dacier. Mind your blocks: On the stealthiness of malicious bgp hijacks. In *NDSS*, 2015.

[43] Haining Wang, Danlu Zhang, and Kang G Shin. Detecting syn flooding attacks. In *Proceedings. Twenty-first annual joint conference of the IEEE computer and communications societies*, volume 3, pages 1530–1539. IEEE, 2002.